

Cybersecurity Incident Registry

Documentazione utente completa

La documentazione descrive funzionalità, flussi operativi, ruoli, incidenti, azioni, notifiche, moduli PDF, report ed export/import.

Indice

1. Panoramica e concetti di base
2. Accesso, ruoli e lingua
3. Pagina principale e ricerca incidenti
4. Creare un nuovo incidente
5. Pagina dello specifico incidente
6. Azioni, allegati e chiusura
7. Avvisi procedurali e controlli prima della chiusura
8. Promemoria schedulati dell'incidente
9. Notifiche e-mail
10. Documenti, moduli PDF e report
11. Export, import e audit visibile all'utente
12. Uso mobile, accessibilità e buone pratiche
13. Esempi operativi
14. Operazioni previste dell'incidente
15. Creazione e aggiornamento incidente da modello
16. Nota sul Full import
17. Rendering Markdown sicuro

cybersecurity-incident-registry

•

Guida pratica per registrare, seguire e chiudere gli incidenti

Questa guida spiega il flusso operativo dell'applicazione con un linguaggio orientato all'uso quotidiano. Ogni capitolo descrive cosa fare, quando farlo e quali controlli verificare prima di procedere.

Le configurazioni avanzate sono descritte nella Documentazione amministrativa . Le novità di versione sono disponibili in Note di rilascio .

Versione applicativa: 0.5.0-1 · Build: 20260522 · Autore: Alessandro De Salvo.

1. Panoramica e concetti di base

Flusso operativo consigliato



Figura 1 - Flusso consigliato di gestione incidente

Un incidente contiene una scheda principale e diversi elementi collegati: azioni cronologiche, personale associato, categorie, dati coinvolti, raccomandazioni, allegati, documenti generati, promemoria e avvisi procedurali. Il registro permette di conservare una traccia ordinata e verificabile delle decisioni prese.

Flusso operativo consigliato

- Aprire l'incidente appena viene rilevato o comunicato.
- Registrare come prima azione l'informazione iniziale, utile per data e ora di venuta a conoscenza.
- Classificare gravità, categorie, dati interessati, personale e raccomandazioni.
- Registrare le attività svolte tramite azioni e allegati.
- Verificare gli avvisi procedurali e inviare le notifiche richieste.
- Produrre report, moduli PDF o documenti di supporto.
- Chiudere l'incidente solo quando non restano avvisi procedurali attivi.

2. Accesso, ruoli e lingua

L'accesso può avvenire con utenti locali, LDAP o SSO/OAuth2/OpenID Connect, secondo quanto configurato dall'amministratore. Se sono presenti più profili SSO attivi, la pagina di login consente di scegliere il provider da utilizzare.

Accesso SSO/OAuth2 dal punto di vista dell'utente

Quando l'amministratore abilita uno o più profili SSO, nella pagina di login compaiono pulsanti dedicati ai provider disponibili. Ogni pulsante può mostrare il logo del provider, così l'utente riconosce rapidamente il metodo di accesso aziendale o istituzionale da usare.

Selezionando un provider SSO, l'utente viene reindirizzato al sistema di identità esterno. Dopo l'autenticazione e l'eventuale verifica a più fattori richiesta dal provider, l'applicazione riceve l'esito del login e apre la sessione con il ruolo

assegnato dall'amministratore. L'utente non deve inserire la password locale dell'applicazione quando usa SSO.

In caso di errore di accesso SSO, verificare di aver scelto il provider corretto e di usare un account autorizzato. Se il login esterno va a buon fine ma l'applicazione non consente l'accesso, contattare un amministratore: può essere necessario abilitare l'utente, associare l'indirizzo e-mail corretto o completare la configurazione del profilo.

Ruolo Operazioni principali

admin Gestione completa di incidenti, configurazioni, utenti, audit, notifiche, moduli, import/export e sicurezza.

writer Creazione e modifica degli incidenti, inserimento azioni, gestione documenti e generazione report.

reader Consultazione degli incidenti e dei report consentiti.

operator Accesso operativo limitato secondo le regole definite dall'applicazione.

L'interfaccia è disponibile in italiano e inglese. Per default viene usato l'italiano con browser in locale italiano e l'inglese per gli altri locale. Gli amministratori possono forzare una lingua da Admin → Altre configurazioni .

3. Pagina principale e ricerca incidenti

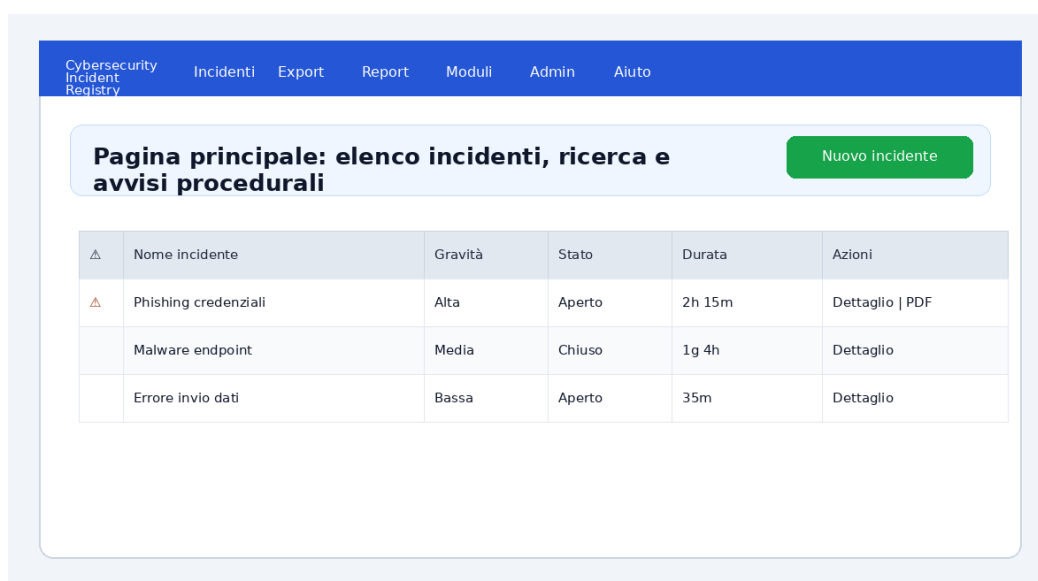


Figura 2 - Pagina principale con avvisi procedurali

La pagina principale mostra gli incidenti visibili all'utente. Ogni riga riporta le informazioni essenziali: titolo, periodo, compilatore, personale associato, stato, durata e comandi disponibili. La durata viene calcolata come nella pagina principale a partire dalla prima azione registrata e dalla data/ora di conclusione, quando disponibili.

Il pulsante Nuovo incidente apre la form di inserimento. La ricerca consente di filtrare rapidamente la lista. Le intestazioni e i controlli di pagina aiutano a individuare gli incidenti aperti, chiusi o con attività ancora da completare.

4. Creare un nuovo incidente

La form di creazione raccoglie i dati iniziali: titolo, descrizione, periodo, stato, gravità, presenza di rischio per diritti e libertà e informazioni organizzative. Compilare i campi disponibili con dati precisi riduce il rischio di dover integrare informazioni prima della generazione dei moduli PDF.

Categorie, dati interessati, personale e raccomandazioni si selezionano con drag & drop. Le raccomandazioni sono limitate dal valore configurato in Admin → Raccomandazioni , con default pari a 3; il limite viene controllato anche lato server.

Checklist di apertura

- Inserire un titolo chiaro e riconoscibile.
- Descrivere i fatti noti senza ipotesi non verificate.
- Associare il personale coinvolto o responsabile.
- Selezionare le categorie e i dati interessati più appropriati.

- Salvare e aggiungere subito l'azione di informazione iniziale se disponibile.

5. Pagina dello specifico incidente



Figura 3 - Dettaglio incidente e timeline azioni

La pagina dello specifico incidente è il punto di lavoro principale. In cima alla pagina è riportato il nome dell'incidente, così resta visibile prima delle fasi procedurali e delle altre schede operative. Nella visualizzazione desktop le fasi procedurali sono distribuite su un massimo di tre step per riga, ogni riga usa tutta la larghezza disponibile e gli step ordinati sono collegati da frecce di sequenza. Ogni step mostra un numero progressivo e il riquadro cliccabile inferiore è evidenziato con un contorno colorato più marcato per rendere chiara l'azione da eseguire; su schermi più piccoli il layout si adatta progressivamente. La scheda principale riepiloga gravità, categorie, dati interessati, personale e informazioni necessarie per procedere. Seguono le sezioni operative per azioni, promemoria, documenti, allegati, moduli PDF e report.

Gli errori relativi a un'operazione vengono mostrati nella sezione in cui l'operazione è stata richiesta. Questo aiuta a capire immediatamente quale azione correggere, senza cercare messaggi generici in cima alla pagina.

Help contestuale della scheda principale

Nella form di modifica/visualizzazione, i campi principali mostrano un simbolo informativo accanto all'etichetta. Passando il mouse sul simbolo, o portandovi il focus da tastiera, viene visualizzato l'help online del campo.

- Nome : nome dell'incidente, obbligatorio.
- Riferimento : campo obbligatorio; identifica il soggetto, utente o riferimento operativo collegato all'incidente.
- Destinatario : destinatario delle comunicazioni; se vuoto viene usato il riferimento.
- Descrizione : descrizione sintetica opzionale.
- Gravità e Stato : livello di gravità e stato operativo, con chiusura automatica possibile solo se non restano avvisi procedurali attivi.
- Data/Ora inizio e fine : periodo della violazione, distinto dalla data/ora di venuta a conoscenza e dalla conclusione amministrativa dell'incidente.
- Rischio per diritti e libertà, Numero interessati e Volume dati : informazioni utili alla valutazione procedurale e alla produzione di comunicazioni e documenti.
- Silenzia notifiche deadline : impedisce le notifiche e-mail automatiche dei task in scadenza per lo specifico incidente.

I tooltip di aiuto dei campi incidente sono disponibili sia nella pagina di creazione sia nella pagina di modifica/dettaglio.

6. Azioni, allegati e chiusura

Le azioni descrivono ciò che è stato fatto sull'incidente. Ogni azione ha una label, una data e ora, una descrizione e, se necessario, allegati. Le nuove azioni possono essere esportabili per default in base alla configurazione della relativa label.

Solo le azioni contrassegnate come esportabili sono considerate per la generazione dei documenti e per i campi dinamici dei moduli PDF, ad esempio l'elenco delle misure adottate.

L'inserimento di un'azione associata al tag amministrativo Chiusura del task in assenza di avvisi procedurali aggiorna automaticamente lo stato dell'incidente a chiuso e imposta data e ora correnti nel fuso orario applicativo, ma solo quando dopo il salvataggio dell'azione non risultano avvisi procedurali attivi. La chiusura viene impedita se restano altri step richiesti mancanti.

Le date e ore predefinite nelle form usano la timezone applicativa configurata; i pulsanti Adesso nei campi inizio/fine permettono di impostare rapidamente il momento corrente nello stesso fuso. Nei report PDF gli orari sono formattati con secondi interi.

7. Avvisi procedurali e controlli prima della chiusura

Gli avvisi procedurali evidenziano gli step del workflow applicabile marcati come richiesti e non ancora completati. La sezione è collocata subito sotto Fasi procedurali, che resta aperta per default così gli operatori vedono subito il quadro complessivo e poi l'elenco puntuale delle attività obbligatorie mancanti. La prima fase procedurale non ancora completata è marcata con una grande freccia rossa, così l'operatore individua subito il prossimo passo operativo.

Ogni voce usa la descrizione operativa dello step, se disponibile, altrimenti la descrizione o il nome del task. Gli step non marcati come richiesti possono restare nel workflow informativo senza generare avvisi procedurali. Nella pagina principale, gli incidenti con avvisi attivi mostrano il simbolo di warning; quelli senza avvisi attivi ma non ancora chiusi mostrano il simbolo di finalizzato; quelli chiusi senza avvisi attivi mostrano il simbolo di ok.

Un incidente con avvisi attivi non può essere chiuso. Il sistema mostra il messaggio nella sezione interessata, permettendo di correggere i dati mancanti o registrare l'azione necessaria.

8. Promemoria schedulati dell'incidente

Per ogni incidente è possibile creare promemoria puntuali con data, ora, messaggio e indirizzi CC opzionali. I destinatari principali sono ricavati dal personale associato all'incidente.

Dalla pagina dello specifico incidente si possono aggiungere, modificare, cancellare e reinviare i promemoria. La sezione è formattata per essere utilizzabile anche da mobile: i campi si dispongono su più righe e non devono uscire dallo schermo.

Nella lista Azioni, ogni azione registrata è contenuta in un riquadro separato collassabile, chiuso per default; l'intestazione riporta le informazioni principali, usando come nome azione la descrizione della label/task se presente oppure il nome della label/task, e l'apertura mostra dettagli, allegati e comandi. Gli utenti con permessi di scrittura possono modificare anche data e ora delle azioni già registrate, oltre a label, descrizione, conseguenze e flag esportabile.

Se l'applicazione viene riavviata, lo scheduler recupera i promemoria specifici scaduti e non ancora inviati. Per i promemoria puntuali vengono inviati tutti quelli con stato sent_at non valorizzato; audit e stato tecnico servono solo per tracciamento e protezione anti-concorrenza, senza bloccare altri promemoria nello stesso periodo.

Il controllo automatico gira in un thread separato con intervallo configurabile nelle impostazioni notifiche, default 60 secondi, e ogni ciclo registra un audit. Gli amministratori possono avviare lo stesso controllo anche da Notifiche → Impostazioni → Controllo promemoria specifici. Se un promemoria viene saltato, l'audit indica il promemoria, l'incidente e il motivo.

9. Notifiche e-mail

Gli utenti abilitati possono consultare in Impostazioni → Notifiche il riepilogo delle prossime notifiche schedulate nelle 24 ore successive, con ora, tipo di notifica, incidente e destinatari previsti.

Le notifiche possono essere inviate manualmente dagli operatori oppure automaticamente dallo scheduler. Le notifiche relative a incidenti includono il link diretto alla pagina dell'incidente solo quando il template contiene esplicitamente il placeholder %INCIDENT_URL%, così l'amministratore controlla il testo inviato.

Importante: l'utente locale admin non può inviare notifiche dalla pagina degli incidenti: la form blocca l'invio e mostra un messaggio esplicito; per inviare notifiche operative occorre accedere con un altro utente autorizzato.

Nell'anteprima delle notifiche manuali è disponibile anche Conferma senza inviare: dopo ulteriore conferma l'applicazione registra l'azione e il PDF della comunicazione prevista senza trasmettere email.

Nell'anteprima di invio è sempre possibile selezionare o deselectare i documenti allegati. Se il template di notifica è associato a un template modulo, i documenti dell'incidente generati da quel modulo sono preselezionati automaticamente; se mancano, viene mostrato un warning non bloccante.

Per le notifiche con destinatario compilabile e non già fissato dalle configurazioni dell'applicazione, l'anteprima di invio mostra la rubrica dei destinatari esterni; la rubrica è ricercabile dalle pagine di gestione con nome ed e-mail: si può scegliere un contatto come destinatario principale oppure aggiungerlo in CC. Il campo resta libero e accetta anche nuovi indirizzi; quando si usa una nuova email, l'applicazione salva automaticamente il contatto nella rubrica condivisa usando il campo Riferimento dell'incidente come nome associato. L'invio viene bloccato con un messaggio di errore se il destinatario resta vuoto; se il template permette la compilazione manuale, un indirizzo valido inserito dall'operatore consente l'invio.

I template delle notifiche manuali possono usare anche %MEASURES_ADOPTED% per la lista delle contromisure adottate, %RECOMMENDATIONS% per la lista delle raccomandazioni da fornire agli interessati, %SITE% per il nome della struttura configurata, %INCIDENT_URL% per il link diretto e %STATISTICS% per allegare il report statistiche in PDF e %APP_INFO% per nome applicazione e versione.

Le notifiche per task con scadenza usano una pianificazione di tipo cron, con orari specifici o intervalli. La pianificazione è calcolata rispetto alla mezzanotte della timezone applicativa e non rispetto all'avvio dell'applicazione; l'intervallo di poll per i task in scadenza è configurabile separatamente e vale 60 secondi per default. Per evitare mail flooding, lo scheduler riserva lo slot prima dell'invio e non invia più volte la stessa notifica per lo stesso incidente nello stesso intervallo.

Per evitare duplicati, l'applicazione tiene traccia dell'ultimo invio riuscito per tipologia/notifica e non reinvia messaggi identici all'interno dello stesso intervallo tra due schedule successive.

Stato notifiche schedulate e CC

La pagina Notifiche mostra lo stato programmata, inviata o errore e gli esiti recenti aggiornati dallo scheduler.

Quando un template consente la modifica manuale del CC, l'anteprima usa il default del template se presente; se l'operatore svuota il campo prima della conferma, l'invio procede senza CC. La checkbox Usa CC per questa notifica, abilitata per default, permette di ignorare il CC per la singola notifica.

10. Documenti, moduli PDF e report

Configurazione moduli PDF: mapping campi e sostituzione template

Campi database incidenti

- Descrizione e causa
- Numero di interessati
- Volume dati
- measures_adopted
- Motivi non garante
- Luogo documentazione

Campi PDF e mapping salvati

- field_1 → Descrizione e causa
- field_2 → Numero di interessati
- field_3 → measures_adopted
- field_4 → Luogo

Sostituisci PDF

Figura 4 - Configurazione moduli PDF e mapping

Esempi di grafici disponibili nella reportistica

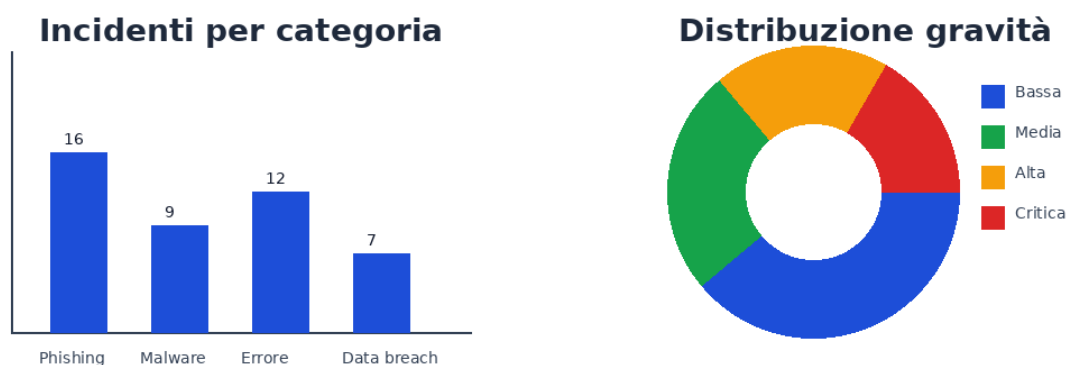


Figura 5 - Esempi di grafici di reportistica

La sezione Documenti consente di allegare file all'incidente. Gli allegati delle singole azioni restano invece collegati alla relativa attività cronologica. I report PDF degli incidenti includono copertina, loghi, indice sintetico, sezioni ordinate, numeri di pagina e durata quando disponibile.

I moduli PDF sono generati a partire dai template configurati dall'amministratore. Quando un template usa campi dinamici basati sulle azioni, vengono incluse solo le azioni contrassegnate come esportabili.

Prima della generazione, se un campo richiesto dal template non è compilato, l'applicazione chiede di inserire i dati mancanti anche per più campi contemporaneamente.

Conseguenze e campo moduli consequences

Il campo moduli consequences unisce le conseguenze automatiche configurate dall'amministratore e quelle eventualmente indicate nelle azioni dell'incidente. La logica automatica è modificabile da Admin → Altre configurazioni .

11. Export, import e audit visibile all'utente

Nella lista dei documenti allegati è possibile taggare ogni file con uno o più tipi di notifica tramite drag & drop. Quando si invia una notifica manuale dello stesso tipo, i documenti taggati vengono preselezionati automaticamente come allegati, ma possono sempre essere deselezionati o integrati con altri documenti. Quando un modulo PDF viene generato e allegato dall'incidente, il documento riceve automaticamente solo i tag dei tipi di notifica attualmente associati dall'amministratore al template modulo usato, così risulta già proposto nell'invio della notifica corrispondente.

Le funzioni di export permettono di salvare dati in CSV o in un archivio completo. Il full export/import include configurazioni, incidenti, documenti, moduli, audit, stato notifiche, certificati SSL e altri dati applicativi previsti.

Le operazioni degli utenti, dello scheduler e dei task automatizzati sono registrate nella tabella di audit. Per ridurre il flooding, i record consecutivi identici vengono collassati e conteggiati; viene comunque scritto un nuovo record ogni 100 occorrenze uguali.

12. Uso mobile, accessibilità e buone pratiche

L'interfaccia è progettata per funzionare anche su schermi piccoli. Tabelle, promemoria e form critiche usano wrapping e layout responsive per mantenere i campi leggibili.

- Usare descrizioni brevi ma complete.
- Allegare evidenze in formato leggibile e con nomi significativi.
- Controllare gli avvisi procedurali prima di generare report o chiudere l'incidente.
- Evitare modifiche non necessarie dopo la chiusura; se indispensabili, documentarle con un'azione.

AI Chatbot AIBot/Alex

Se il plugin è attivato dall'amministratore, il menu Aiuto e il launcher globale rendono disponibile AIBot , chiamabile anche Alex , per supporto sulle funzioni dell'applicazione e sulle procedure per gli incidenti di sicurezza.

Quando il contesto database è abilitato, il chatbot usa solo uno snapshot sanitizzato delle configurazioni e dello stato applicativo, senza inviare dati personali, segreti o allegati binari al motore AI. Il widget è posizionato in modo da evitare sovrapposizioni con logo, bordi viewport ed elementi fissi; su mobile si apre dal pulsante in alto accanto al menu.

13. Esempi operativi

Incidente tecnico senza rischio per diritti e libertà

- Aprire l'incidente e descrivere il problema tecnico.
- Associare personale e categorie rilevanti.
- Registrare analisi, mitigazione e ripristino come azioni.
- Allegare log o report tecnici.
- Verificare l'assenza di avvisi e chiudere con azione di conclusione.

Incidente con possibile data breach

- Registrare immediatamente l'informazione iniziale.
- Compilare rischio per diritti e libertà, categorie, gravità e soggetti coinvolti.
- Valutare gli avvisi procedurali, inclusa la notifica all'utente richiesta quando applicabile.
- Generare i moduli PDF necessari e inviare le notifiche previste.
- Produrre il report finale e chiudere solo dopo la risoluzione degli avvisi.

14. Operazioni previste dell'incidente

Nella pagina dello specifico incidente, in cima alla form, viene mostrata la lista delle operazioni previste fino alla conclusione. Le operazioni già effettuate sono evidenziate in verde, quelle ancora mancanti in arancione; se un task con tempo massimo risulta scaduto, la scadenza viene evidenziata ulteriormente.

La didascalia di ogni step usa la descrizione del task configurata nella lista azioni, se presente, altrimenti il nome del task; gli step marcati come richiesti generano avvisi procedurali finché non sono completati. L'amministratore può aggiungere una descrizione operativa ulteriore sul singolo step del workflow, anche su più righe e fino a 500 caratteri, utile quando la stessa azione compare più volte con significati diversi. La descrizione visualizzata negli step supporta un sottoinsieme sicuro di Markdown per grassetto, corsivo, codice inline, titoli, elenchi e link. Eventuali URL presenti nella descrizione sono cliccabili senza modificare il comportamento generale del riquadro dello step. Per evidenziare parti del testo si può usare anche `{color:red}testo rosso{/color}` o `{color:#0b7285}testo colorato{/color}` ; per la dimensione del testo sono supportati valori controllati come `{size:large}testo grande{/size}` o `{size:14px}testo 14px{/size}` . Lo stesso Markdown è applicato agli avvisi procedurali, dove viene mostrato anche il nome del task associato.

Quando l'azione prevista ha un tempo massimo, la scheda mostra limite, scadenza e tempo rimanente solo finché lo step non risulta effettuato. Se il tempo rimanente è minore o uguale a zero, lo step mancante viene evidenziato come critico. Il calcolo parte dall'azione di informazione iniziale, come per le notifiche automatiche dei task in scadenza.

Il flusso deriva dalle categorie associate all'incidente; con più categorie i flussi vengono sommati e i duplicati rimossi. Se nessuna categoria ha un flusso dedicato viene usato il flusso di default configurato dall'amministratore: Informazione iniziale, Analisi, Notifica allo CSIRT, Notifica al DPO, Comunicazione al Garante, Comunicazione all'utente e Conclusione. Anche il flusso di default è modificabile dall'amministratore.

15. Creazione e aggiornamento incidente da modello

Nella pagina Nuovo incidente è possibile scegliere un modello predefinito, se configurato dall'amministratore. Il modello compila automaticamente i dati iniziali dell'incidente, mentre data e ora di inizio sono impostate al momento corrente.

Nella pagina del singolo incidente, sezione Dati generali , il menu Applica modello incidente consente di autocompilare i campi del form con i valori del modello selezionato. La selezione non modifica immediatamente il record: l'utente può verificare o correggere i valori e deve premere Salva per rendere effettive le modifiche. Azioni, documenti e allegati già presenti non vengono alterati dal modello.

Nella sezione Azioni , il pulsante  accanto a data e ora aggiorna il campo al momento corrente prima dell'inserimento dell'azione.

16. Nota sul Full import

Il Full import è una funzione amministrativa di ripristino totale. Quando viene eseguito, il database viene ricreato completamente e sostituito con i dati dell'archivio importato. Gli utenti operativi devono richiederlo solo come procedura controllata di ripristino o migrazione.

17. Rendering Markdown sicuro

Le viste che mostrano Markdown applicativo, incluse descrizioni workflow, avvisi procedurali, pagina chatbot e widget chatbot, supportano un sottoinsieme sicuro: titoli, elenchi, grassetto, corsivo, codice, link HTTP/HTTPS e pulsanti link con sintassi {button:Etichetta|URL}.

I pulsanti possono puntare sia a URL assoluti HTTP/HTTPS sia a destinazioni relative alla pagina corrente, ad esempio {button:Dati generali|#incident-main}, {button:Azioni|#incident-actions} o {button:Apri guida/help#cap-markdown-rendering}. Per evidenziare il testo sono disponibili tag controllati come {color:red}testo{/color}, {color:#0b7285}testo{/color}, {size:large}testo{/size}, {size:14px}testo{/size}, {size:1.2em}testo{/size} e {size:120%}testo{/size}. L'HTML libero resta escapato; le notifiche schedate rimuovono la formattazione Markdown prima dell'invio.